

정보시스템보안 지침



주식회사 모인

개정 이력

[illegible]

정보시스템 보안 지침

소관부서 : 정보보안팀

제1장 총칙

제1조(목적) 이 지침은 주식회사 모인(이하 “회사”라 한다)의 안전하고 지속적인 서비스 제공을 위하여 정보처리시스템 운영 과정에서 정보보안 활동을 위하여 필요한 보안통제 절차에 관한 정의를 목적으로 한다.

제2조(적용 범위) 이 지침은 회사 내의 정보시스템과 이를 관리 및 이용하는 모든 임직원에게 적용한다.

제3조(용어의 정의) 이 지침은 다음 용어 정의를 따른다.

1. “정보처리시스템”이란 정보통신기술을 이용할 수 있는 근간이 되는 시스템들로서, 서버 시스템, 네트워크 장비, DBMS를 의미한다.
2. “네트워크 장비”란 네트워크를 위하여 사용하는 라우터, 허브, 스위치 등과 이를 운영하기 위하여 필요한 장비를 말한다.
3. “데이터베이스관리시스템(Database Management System, 이하 ‘DBMS’라 한다)”란 DB를 효과적으로 관리·이용하기 위하여 데이터의 추가, 변경, 검색 등의 기능을 제공하는 소프트웨어 패키지를 말한다.
4. “정보보호시스템”이란 정보시스템 내에 있는 정보를 유출·위변조·훼손하거나 정보시스템의 정상적인 서비스를 방해하는 침해행위로부터 정보 등을 보호하기 위한 장비 및 프로그램을 말한다.
5. “공개용 웹서버”란 인터넷 이용자들이 웹페이지를 자유롭게 보고 웹서비스(World Wide Web)를 이용한 서비스를 말한다)를 이용할 수 있게 해주는 프로그램을 실행하는 장치를 말한다.
6. “개인정보처리시스템”이란 데이터베이스시스템 등 개인정보를 처리할 수 있도록 체계적으로 구성한 시스템을 말하며, 개인정보처리를 위하여 데이터베이스가 연결되어 구성된 경우 웹서버, 어플리케이션 서버, 중계 서버도 개인정보처리시스템에 포함된다.
7. “접근통제”란 정보시스템에 대한 접근을 제한하고 통제하는 프로세스로 비 인가 접근이나 사용으로부터 시스템을 보호하기 위한 논리적, 물리적인 통제를 말한다.
8. “로그”란 서버의 사용에 관련된 기록, 즉 입·출력내용, 프로그램 사용내용, 자료 변경내용, 시작시간, 종료시간 등의 기록을 총칭한다.
9. “패치”란 각종 소프트웨어, 운영체제 등에서 발견되는 보안상의 취약성을 보완해주는 프로그램을

말한다.

10.“시간 동기화”란 네트워크상의 각 서버에 대해 작동시각을 일치시키는 행위를 말한다.

11.“무선침입 방지시스템(WIPS: Wireless Intrusion Prevention System)”이란 무선 AP(Access Point) 사용 현황을 실시간으로 모니터링하고, 허용하지 않은 접속을 차단하는 시스템을 말한다.

제2장 책임 및 권한

제4조(시스템 운영관리자)

- 1 시스템 운영관리자는 정보시스템의 안전한 운영 활동에 대한 최종 책임을 갖는다.
- 2 시스템 운영관리자는 정보시스템의 효율적 운영을 위하여 시스템 운영자를 지정해 단위 업무를 위임할 수 있다. 다만, 해당 업무를 위임한 경우라도 시스템 운영관리자의 책임은 위임되지 않는다.
- 3 시스템 운영관리자는 시스템 운영자의 정보보안 활동에 대하여 총괄 관리 및 지원하여야 한다.

제5조(시스템 운영자)

- 1 시스템 운영자는 서버 및 네트워크, DBMS, 정보보호시스템을 운영하는 실무 담당자이며, 정보시스템의 운영 관리 및 정보보안 통제 실행에 대한 실무 이행 책임을 가진다.
- 2 시스템 운영자는 정보시스템 운영을 위탁하는 경우 위탁운영업체가 이 지침 및 관련 보안지침을 준수하도록 지시하고, 이를 감독할 책임을 가진다.
- 3 시스템 운영자는 정보시스템에 대하여 계정을 발급·회수·삭제에 대한 업무를 수행하며, 계정관리에 대한 책임을 가진다.
- 4 시스템 운영자는 담당하는 정보시스템에 불필요한 계정이 존재하지 않도록 주기적으로 검토 및 관리하여야 한다.
- 5 시스템 운영자는 정보시스템의 계정 관리에 대한 이행 책임을 가진다.
- 6 시스템 운영자는 부재 시에도 정보시스템 운영이 원활하게 이루어질 수 있도록 정보시스템 별 운영매뉴얼을 수립하고 주기적으로 검토하여야 한다.
- 7 정보시스템의 안전하고 지속적인 운영을 위하여 이 지침의 정보보안 요구사항에 대한 이행 책임을 가진다.
- 8 정보시스템 신규 도입 또는 변경 단계에서 발견된 취약점이 제거될 수 있도록 조치하여야 한다.
- 9 시스템 운영자는 정보시스템 운영상 발생하는 보안 이슈들에 대하여 정보보호 담당자에게 협조를 요청할 수 있다.

제6조(정보보호 담당자)

- 1 정보보호 담당자는 정보시스템 운영에 있어서 보안정책 및 보안업무를 관리하고 검토에 대한

책임을 가진다.

- 2 정보보호 담당자는 시스템 운영자에게 이 지침과 관련 보안지침을 준수하도록 지시하고, 이를 감독할 책임을 가진다.
- 3 정보보호 담당자는 시스템 운영자가 보안정책 변경 및 취약점을 제거할 수 있도록 협조하여야 한다.

제3장 정보시스템 운영 관리

제7조(정보시스템 도입 계획 수립) 시스템 운영관리자는 연 1회 이상 H/W 및 S/W 장비에 대한 현황 및 수요를 조사하고, 조사결과를 토대로 다음 각 호의 내용을 고려한 IT자산관리 계획을 수립하여야 한다.

- 1 현재 시스템 자원의 이용률, 사용 용량, 한계성에 대한 분석
- 2 추가 자원의 필요성 및 시기에 대한 예측
- 3 시스템 구성, 성능, 안정성, 신뢰성, 보안성을 포함한 시스템 자원의 기능적·운영적 요구사항 등

제8조(정보시스템 변경)

- 1 시스템 운영자는 정보시스템 변경(교체, 신규 설치 등)이 필요한 경우에는 변경에 따른 보안, 성능, 업무 등에 미치는 영향을 분석하여야 한다.
- 2 시스템 운영자는 변경작업 수행 시 대상 시스템, 작업 계획, 변경 전후 내역, 변경 시 영향도 등을 포함한 작업요청서를 작성하여 시스템 운영관리자의 승인을 받아야 한다.
- 3 시스템 운영자는 정보시스템 용도 변경 시에는 저장되어 있는 정보 및 설정을 삭제하여야 한다.
- 4 시스템 운영자는 변경 시 장애 발생에 대비하여 복원 절차를 마련하여야 한다.
- 5 시스템 운영자는 중대한 변화가 있을 시에는 변경관리 절차에 따른 행위를 모두 기록하고 관리하며, 중대한 변화는 다음 각 호의 사항을 포함한다.
 - 1) 인수, 합병, 사무실의 이전
 - 2) 데이터센터의 신설, 이전
 - 3) 네트워크 존(zone)의 신설 및 변경
 - 4) 대규모 시스템 도입
- 6 시스템 운영자는 제5항의 중대한 변화에 해당되지 않은 시스템의 신규 도입과 변경, 운영체제의 업그레이드, 방화벽 정책의 변경 등에 해당하는 경우에도 중대한 변화에 따른 변경관리 절차를 준용하여 각각의 변경작업에 맞는 필요한 조치를 진행하고 기록을 관리한다.

제9조(정보시스템 인수)

- 1 시스템 운영자는 정보시스템(서버, 네트워크, DBMS, 정보보호시스템 등) 인수 시 보안설정이

적용될 수 있도록 하여야 한다.

- 2 시스템 운영자는 제1항에 따른 보안설정이 적용되도록 정보시스템별 점검기준에 따라 취약점 점검 및 보안성 검토 등 보안설정을 적용하고 적합성 여부를 검토하여 정보보호 담당자의 승인을 받아야 한다.
- 3 시스템 운영자는 환경 구성 및 서비스에 따라 보안설정을 적용할 수 없는 경우, 대체 보안 방안을 수립하여 정보보호최고책임자(이하 “CISO”라 한다)의 승인을 받은 후 예외 처리할 수 있다.

제10조(정보시스템 패치)

- 1 시스템 운영자는 월 1회 이상 제조사 및 유지보수 업체로부터 각 정보시스템의 패치 정보를 받고, 패치 필요성 및 영향도 검토를 수행하여야 한다.
- 2 시스템 운영자는 제8조에 따라 패치를 수행하여야 한다.
- 3 인터넷을 통한 패치는 원칙적으로 금지하여야 한다.
- 4 시스템 운영자는 패치관리시스템(PMS: Patch Management System)을 통하여 정보시스템을 패치하는 경우, 패치 파일에 대한 무결성 검증 및 서비스 가용성에 대한 영향도 분석을 수행하여야 한다.
- 5 시스템 운영자는 긴급하고 중요한 보정(patch)사항에 대하여는 즉시 패치를 적용하여야 한다.
- 6 시스템 운영자는 패치의 중요도 등급에 따라 패치 계획을 수립하고, 패치 적용이 불가능한 경우 정보보호 담당자의 보안성 검토 후 CISO의 승인을 받아 설치를 유예할 수 있다.

제11조(정보시스템 유지보수)

- 1 회사의 서버, DBMS, 응용프로그램 등의 정보시스템 유지보수는 원칙적으로 통제구역 내에서 시스템 운영자의 동행 하에 유지보수를 원칙으로 하며, 외부반출이 필요한 경우에는 시스템 운영관리자의 승인 후 이루어져야 한다.
- 2 시스템 운영자는 제1항에 따른 정보시스템 유지보수 시 작업일, 작업내용, 작업결과 등을 기록한 유지보수관리대장을 작성하고 보관한다.
- 3 시스템 운영자는 PC를 포함한 정보시스템의 고장 수리 또는 불용처리 등으로 인하여 외부로 반출하는 경우 저장매체를 분리하여 반출하여야 한다.

제12조(정보시스템 폐기)

- 1 시스템 운영자는 폐기 대상 자산을 파악하여 대상 시스템, 폐기 사유, 폐기 일시, 폐기 방법 등을 포함한 신청서를 작성하여 정보보호 담당자에게 요청하고, 정보보호 담당자는 신청서를 검토하고 요청에 따라 폐기를 수행한다.
- 2 시스템 운영자는 PC를 포함한 정보시스템 폐기 시, 시스템 구성이나 데이터 등 저장되어 있는

정보가 복구되지 않도록 다음 각 호의 물리적 또는 전자적으로 폐기한다.

- 1) 물리적 폐기: 소각, 파쇄 등
- 2) 전자적 폐기: 디가우저 등
- 3 시스템 운영자는 외부업체를 통해 저장매체를 폐기할 경우, 내부 폐기정책과 절차내용을 계약서에 명시하고 데이터 유출 방지 및 책임에 대하여 「보안서약서」를 징구한다.
- 4 정보보호 담당자는 폐기 현장에 동행하여 감독하거나 폐기 증적으로 사진, 동영상 등 폐기 확인서를 징구하여 검토하고, 폐기가 정상적으로 완료되었을 경우 폐기 일자, 폐기 자산, 폐기 방법 등을 기록·관리하여야 한다.
- 5 시스템 운영자는 저장매체를 폐기하지 않고 재사용이 필요한 경우 저장된 데이터를 복구되지 않는 방법으로 삭제한 후 사용하여야 한다.

제13조(시각동기화)

- 1 시스템 운영자는 모든 운영 서버에서 발생할 수 있는 보안사고에 대한 정확한 기록을 보증하기 위하여 다음 각 호의 내용에 따라 모든 정보시스템 시간을 내부 타임서버와 주기적으로 동기화 시킨다.
 - 1) 시간 동기화는 자동화된 NTP(Network Time Protocol)를 사용하거나 수동 설정 방법을 사용하여 수행한다.
 - 2) 내부 타임서버는 협정세계시(UTC) 또는 국제원자시(International Atomic Time)를 기반으로 신뢰할 수 있는 외부 타임서버와 시간을 동기화 한다.
 - 3) 내부 타임서버는 인가된 사용자만 접근을 허용하여야 하며, 설정의 변경사항을 로그로 기록하고 모니터링 되어야 한다.

제4장 정보시스템 보안 관리

제1절 접근통제

제14조(정보시스템 접근통제)

- 1 회사는 정보시스템으로의 접속은 인가된 사용자만 허가 받은 IP에서 접근할 수 있도록 제한하여 비인가자가 접속할 수 없도록 엄격히 통제하여야 한다.
- 2 시스템 운영자는 정보시스템에 다음 각 호와 같은 통제절차를 적용하여야 한다.
 - 1) 암호화된 인증 방법 사용(SSH 등)
 - 2) 60분 이상 입력이 되지 않을 때 자동 세션 종료
 - 3) 연속적으로 5회 이상 비밀번호를 잘못 입력한 사용자의 경우 즉시 접근을 제한

3 시스템 모니터링을 담당하는 부서는 월 1회 정보시스템에 대한 접근내역을 검토하여 정보보호 담당자에게 공유하여야 한다.

제15조(정보시스템 외부 접근)

- 1 회사는 정보시스템 관리를 위하여 인터넷 등을 통하여 외부에서 원격 접속하는 것을 금지하여야 한다. 다만, 불가피한 경우 사용자는 비상 대책에 따라 사전에 원격 접속 신청서를 작성하여 정보보호 담당자에게 승인을 득한 후 접속하여야 한다.
- 2 정보보호 담당자는 승인받은 원격 접속 사용자 목록을 기록·관리하여야 한다.
- 3 원격 접속 사용자는 외부에서의 정보시스템 접근 시 가상사설망(Virtual Private Network, 이하 “VPN”이라 한다) 인증을 통해 보안통제가 설정된 회사 내부의 원격접속용 VDI로 접속 후 정보시스템에 접속하여야 하며, VPN 사용자 인증 시 ID와 비밀번호 외 추가인증을 적용하여야 한다.
- 4 원격 접속 사용자가 외부에서 접속하는 원격접속 단말기에 대한 보안사항은 단말보안 지침에서 정한 사항에 따른다.
- 5 시스템 운영자는 외부에서의 정보시스템 접근 이력 및 수행한 작업 내역을 매일 검토하여 정보보호 담당자에게 공유하여야 한다.

제2절 로깅 및 모니터링

제16조(로그관리)

- 1 시스템 운영자는 정보시스템 운영 과정에서 발생하는 보안사고 확인을 위하여 다음과 같은 로그를 생성하고 최소 1년 이상 보관하여야 한다.
 - 1) 정보처리시스템에 접속한 일시, 접속자 및 접근을 확인할 수 있는 접근기록
 - 2) 전산자료를 사용한 일시, 사용자 및 자료의 내용을 확인할 수 있는 접근기록
 - 3) 정보처리시스템내 전산자료의 처리 내용을 확인할 수 있는 사용자 로그인, 액세스 로그 등 접근기록
 - 4) 관리자 권한을 소유한 계정의 활동 내역에 대한 로그
 - 5) 운영 과정에서 나타난 비정상 이벤트 및 프로세스 오류에 대한 로그
 - 6) 응용프로그램 및 시스템 소프트웨어 로그(Apache, IIS 등)
 - 7) 정보시스템 가동기록(가동 시간, 시스템 자원, 장애상태 등)
 - 8) 이용자 정보 조회 로그(사용자, 사용일시, 변경·조회내용, 접속방법)
 - 9) 기타 정보시스템 운영을 위하여 필요한 사항 등
- 2 시스템 운영자는 개인정보처리시스템의 접근 권한 부여, 변경 또는 말소에 대한 로그를 생성하고, 최소 5년 이상 보관하여야 한다.

3 시스템 운영자는 로그의 기록 시 다음의 사항을 준수하여야 한다.

- 1) 정확한 로그 분석을 위해 제13조에 따른 정보시스템의 시각 동기화
 - 2) 정보보호 담당자와의 협의 하에 주요 서버의 성능 및 디스크 용량 등을 고려하여 로깅 대상 선정
 - 3) 로그에 대한 접근통제 대책 적용
- 4 시스템 운영자는 로그기록을 별도 저장장치를 통해 백업하고 로그기록에 대한 접근권한 부여를 최소화하여야 한다.

제17조(로그 분석 및 모니터링)

- 1 시스템 운영자는 로그에 대하여 분석 및 모니터링하고, 그 결과 침해사고 발생이 의심되는 이상 징후가 발견된 경우 정보보호 담당자와 협의하여 침해사고 대응지침에 따라 처리하여야 한다.
- 2 시스템 운영자는 매월 개인정보처리시스템의 접속기록을 다음 각 호에 따라 검토하고 그 결과를 정보보호 담당자에게 공유하여야 한다.
 - 1) 업무목적 이외의 중요정보 과다처리 (조회, 변경, 삭제 등)
 - 2) 업무시간 외 접속, 비정상적인 접속 (미 승인 계정 접속 등)
 - 3) 개인정보 다운로드 여부 및 다운로드 시 사유 확인 등
- 3 정보보호 담당자는 매월 전달받은 로그 분석 및 모니터링 결과를 검토하여 이상유무를 확인하여야 한다.

제18조(침해시도 모니터링)

- 1 시스템 운영자는 외부로부터의 침해시도 및 이상징후를 인지할 수 있는 방화벽 및 웹 방화벽, 침입방지시스템(IPS) 등의 정보보호시스템을 운영하여야 한다.
- 2 시스템 운영자는 정보보호시스템 이벤트 로그를 모니터링 하여야 한다.
- 3 시스템 운영자는 침해시도를 24시간 365일 모니터링 하여야 하며, 침해시도가 발생한 내역에 대하여 기록하여야 한다.
- 4 시스템 운영자는 침해시도 발생 시, 즉시 정보보호 담당자에게 알려야 한다.
- 5 시스템 운영자는 정보보호시스템 운영 내역과 침해시도 모니터링 내역을 검토하여 매월 정보보호 담당자에게 공유하여야 한다.

제19조(성능 및 용량 관리)

- 1 시스템 운영자는 주요 정보시스템 및 정보보호시스템을 식별하여 정기적으로 정보처리시스템의 사용 현황 및 추이 분석 등을 실시하여 성능 및 용량을 관리하여야 한다.
- 2 시스템 운영자는 계획된 방법과 도구로부터 성능 정보를 수집하고, 성능에 영향을 주는 이벤트가 발생하는지 모니터링 하여야 한다.

3 시스템 운영자는 정기점검 및 모니터링 결과를 분석하여 다음 각 호를 고려한 개선계획을 수립하여야 한다.

- 1) 요구사항, 성능 복구 방안, 유지보수 현황
- 2) 개선 구축 효과 및 비용, 용량 증산 타당성 등

제3절 장애 및 업무 연속성 관리

제20조(장애 대응)

- 1 시스템 운영자는 장애 발생 시 지체 없이 장애 상황에 대하여 시스템 운영관리자에게 보고하고, 장애일시, 장애내용 및 조치사항 등을 기록한 장애상황 기록부를 상세하게 작성·보관하여야 한다.
- 2 시스템 운영자는 장애 발생에 따른 복구 절차에 따라 시스템 및 서비스를 복구하여야 한다.
- 3 시스템 운영자는 서비스 별 장애처리 담당자와 외부업체의 연락처가 포함된 비상연락망을 작성하여 항상 최신 정보로 유지하여야 한다.

제21조(백업 관리)

- 1 시스템 운영자는 시스템 장애, 가동중지 등 긴급사태에 대비하여 정보시스템의 백업 및 복구 절차 등을 수립·시행하여야 한다.
- 2 시스템 운영자는 정보보호 담당자 및 관련 부서와 협의를 통해 데이터의 중요도, 법적 요건 등을 고려하여 백업 방법, 백업 대상 및 주기를 설정하여야 한다.
- 3 시스템 운영자는 백업 데이터가 원본과 동시에 손실되는 것을 방지하기 위해 물리적으로 떨어진 안전한 장소에 소산하고, 백업 및 소산 내역을 기록·관리하여야 한다.
- 4 제3항에 따른 소산 시 백업 데이터가 유실되거나 손상되지 않도록 안전한 방법으로 소산하여야 한다.
- 5 시스템 운영자는 주요 백업 전산자료의 경우 백업정보의 완전성, 정확성 등을 점검하기 위하여 정기적으로 복구 테스트를 수행하여야 한다.

제22조(운영 매뉴얼) 시스템 운영자는 비상시 원활한 정보시스템 운영을 위하여 정보시스템에 대한 구동, 조작 방법, 명령어 사용법, 운용 순서, 장애 조치 및 연락처 등이 기록된 시스템 운영 매뉴얼을 작성하고 최신으로 관리하여야 한다.

제23조(이중화 구성) 전자금융업무를 지원하는 정보시스템 및 통신회선은 장애로 인한 서비스 중단 등이 발생하지 않도록 이중화 구성을 원칙으로 한다.

제5장 정보시스템별 보안 요구사항

제1절 서버

제24조(기능 관리)

- 1 시스템 운영자는 하나의 서버에 보안수준이 상이한 기능을 함께 구성하지 않으며, 서버 당 하나의 주요 기능을 갖도록 구성해야 한다. 다만, 가상화 기술을 사용하는 경우 하나의 가상 시스템 구성요소 단위로 하나의 기능을 갖도록 구현한다.
- 2 서버에는 보안에 취약하지 않은 서비스나 프로토콜만 사용해야 하며, 업무 목적으로 불가피하게 사용해야 하는 경우 정보보안팀과 협의하여 보안대책 수립 후 사용하여야 한다.

제25조(백신 설치 및 운영)

- 1 시스템 운영자는 서비스의 안정성이 검증된 최신 버전의 백신을 설치 및 운영하여야 하며, 바이러스 백신 설정 정책에 따라 백신을 설치 및 검사 주기 등을 설정하여야 한다.
- 2 시스템 운영자는 백신프로그램의 패치 설치 시 패치 파일의 무결성 검사를 수행하고, 이상이 없을 시 백신 패치를 수행하여야 한다.
- 3 시스템 운영자 및 서버 시스템 사용자는 서버 바이러스 감염 시 피해를 최소화할 수 있도록 내부 절차에 따라 즉시 조치하여야 한다.
- 4 시스템 운영자는 백신프로그램을 설치할 수 없는 서버에 대해 별도의 악성코드 방지 대책을 수립하고 보안 공지와 뉴스 등의 동향을 지속적으로 파악하여 악성코드 감염에 대비하여야 한다.

제26조(공개용 웹서버 보안관리)

- 1 시스템 운영자는 공개용 웹서버의 안전한 관리를 위하여 다음 각 호를 포함한 적절한 대책을 수립·운영하여야 한다.
 - 1) 공개용 웹서버를 내부통신망과 외부통신망 사이의 독립된 통신망(이하 “DMZ 구간”이라 한다)에 설치하고 네트워크 및 웹 접근제어 수단으로 보호
 - 2) 공개용 웹서버에 접근할 수 있는 사용자 계정은 업무 관련자만 접속할 수 있도록 제한하고 계정 및 비밀번호 이외의 추가 인증수단 적용
 - 3) 공개용 웹서버에서 제공하는 서비스를 제외한 다른 서비스 및 시험, 개발 도구 등의 사용 제한
 - 4) 웹서버와 같은 공개 서버에 중요정보 및 개인정보를 저장·게시하는 것은 원칙적으로 금지하여야 하며, 거래로그를 관리하기 위해 이용자 정보 등의 저장이 필요한 경우 암호화하여 저장·관리
 - 5) 웹서버를 통한 개인정보 및 금융정보 송·수신 시 보안소켓레이어(Secure Socket Layer, SSL)/전송레이어보안(Transport Layer Security, TLS) 인증서 설치

- 6) 불필요한 서비스 및 포트 삭제 등
- 2 회사는 인터넷 홈페이지 등 공개용 웹 서버에 게재된 내용에 대하여는 다음 각 호의 내용을 준수한다.
- 1) 게시자료에 대한 사전 내부통제 실시
 - 2) 무기명 또는 가명에 의한 게시 금지
 - 3) 홈페이지에 자료를 게시하는 담당자의 지정. 운영
 - 4) 개인정보의 유출 및 위. 변조 방지를 위한 보안조치
- 3 회사는 인터넷 홈페이지를 통한 침해사고가 발생하지 않도록 반기 1회 이상 취약점을 점검하고 발견된 취약점에 대하여 신속하게 조치를 취하여야 한다.

제27조(DNS 서버 보안관리)

- 1 시스템 운영자는 반드시 도메인 네임 시스템(Domain Name System, 이하 “DNS”라 한다) 서버에는 DNS 서비스와 관련이 없는 모든 불필요한 소프트웨어는 제거하여야 한다.
- 2 DNS 서버에 대한 각종 오남용을 예방하기 위하여 보안 설정을 적용하여야 한다.
- 3 시스템 운영자는 DNS 서버의 접근 로그를 기록하여 불법 침입 및 침입 시도를 모니터링 하여야 한다.
- 4 시스템 운영자는 DNS 서버의 오남용 공격 또는 과도한 질의로 인한 장애에 대비하기 위하여 주기적으로 모니터링 하여야 한다.

제2절 네트워크

제28조(네트워크 구성 관리)

- 1 시스템 운영자는 네트워크 구성 변경 시 이 지침 제8조에 따른 절차를 준수하여야 하며, 자체적 보안성 검토를 수행하여야 한다.
- 2 시스템 운영자는 회사의 네트워크 장비의 목록, 구성도, IP 현황, 설정 파일 등을 최신으로 유지하여야 하며, 대외비 이상으로 안전하게 관리하여야 한다.
- 3 회사의 네트워크는 서비스, 정보자산의 중요도, 법적 요구사항에 따라 물리적 또는 논리적으로 분류하고 비인가자의 접근을 통제하여야 한다. 다만 다음 각 호의 경우에는 그러하지 아니한다.
 - 1) 이용자의 고유식별정보 또는 개인신용정보를 처리하지 않는 연구·개발 목적의 경우 자체 위험성 평가를 실시 한 후 망분리 대체 정보보호 통제를 적용 후 정보보호 위원회가 승인 한 경우
 - 2) 업무상 불가피한 경우로서 금융감독원장이 인정하는 경우
- 4 회사는 물리적으로 떨어진 IDC 센터 등과의 네트워크 연결 시 전용회선을 구축하여야 하며,

전용선의 구축이 불가능한 경우 VPN 등의 보안대책을 마련하여야 한다.

5 회사의 내부통신망은 다른 기관의 내부통신망과 분리하여 사용하여야 한다.

제29조(IP주소 관리 대책)

1 회사의 내부 네트워크에서 사용되는 IP 주소는 국제표준에 따른 사설 IP대역을 사용하여야 하며, 내부 IP 주소 체계가 외부에 유출되지 않도록 네트워크 주소변환(Network Address Translation, NAT) 기능을 통해 보호하여야 한다.

2 시스템 운영자는 업무 특성에 따라 네트워크를 적절하게 분리하여 사용자별 IP를 부여하여야 한다.

3 시스템 운영자는 내부 IP 주소 및 외부 IP 주소의 인터넷 접속 내용을 1년 이상 별도로 기록하여야 한다.

4 시스템 운영자는 IP 운영 현황을 지속적으로 관리하여야 하며, 매월 IP 운영 현황을 검토하여야 한다.

제30조(무선네트워크 보안)

1 회사는 무선네트워크의 설치 및 운용의 경우 이를 원칙적으로 금지하며, 부득이한 경우 이용 업무를 최소한으로 국한하고 CISO의 승인을 받은 후 구축하여야 한다.

2 회사가 제1항에 따라 무선네트워크를 구축하는 경우에는 다음 각 호의 보안대책을 적용하여야 한다.

1) 네트워크 이름(SSID, Service Set Identification) 브로드캐스팅 중지 및 추측하기 어려운 SSID 사용

2) WPA2 이상(256비트 이상)의 암호체계를 사용한 암호화 적용

3) 주기적인 비밀번호 변경

4) ID와 비밀번호 단말기의 MAC주소 인증 등의 외 추가 인증 등

3 회사의 무선네트워크는 내부 임직원들만 사용을 허가하며, 외부직원의 무선네트워크 접근은 원칙적으로 금지하여야 한다.

4 회사는 지정된 업무 용도와 사용 지역(zone) 이외의 무선네트워크에 접속하는 것을 차단하기 위한 차단시스템을 구축하고 실시간 모니터링체계를 운영하여야 한다.

5 시스템 운영자는 비인가 무선접속장비(AP) 설치·접속여부, 중요 정보 노출여부를 주기적으로 점검하여야 한다.

제3절 데이터베이스

제31조(DBMS 접근통제)

1 시스템 운영자는 데이터베이스 접근권한이 데이터베이스의 테이블, 뷰, 레코드 등 가능한 상세한

수준에서 통제되도록 하여야 한다.

2 시스템 운영자는 데이터베이스 시스템 접근 권한을 업무 권한에 따라 적정하게 구분, 운용한다.

3 DBMS 접근은 DB접근통제 솔루션을 통해서만 접근하고, 직접 접근이 필요한 경우 CISO의 승인을 받은 경우에만 허용한다.

4 DBMS 접속은 허가된 사용자만 지정된 IP에서 접근하여야 하며, 추가 인증을 통해 사용자 보안 강화를 강화하여야 한다.

5 중요정보(개인정보, 기밀정보 등)를 저장하고 있는 DBMS 및 WAS는 외부에 서비스를 제공하는 공개 네트워크 영역(DMZ: Demilitarized Zone)에 위치하여서는 안 된다.

6 데이터베이스의 접근통제 시스템 또는 분산된 데이터베이스 시스템 간의 네트워크 접근통제 시스템이 정상적으로 작동되지 않을 때에는 일반 사용자의 접근을 허용하지 않아야 한다.

7 시스템 운영자는 매월 DBMS 접속기록을 검토하여 정보보호 담당자에게 그 결과를 공유하여야 한다.

제32조(데이터베이스 저장 시 암호화)

1 회사는 중요 정보 노출 방지를 위하여 다음 각 호의 정보에 대하여 암호화하여 저장하여야 한다.

- 1) 주민등록번호, 여권번호, 외국인등록번호, 운전면허번호의 고유식별정보
- 2) 지문, 홍채, 얼굴, 정맥, 음성 등 바이오정보
- 3) 로그인 비밀번호, 카드 비밀번호, 계좌 비밀번호 등 비밀번호
- 4) 카드번호(신용/직불) 등 거래 관련 정보 등

2 회사의 암호화는 DBMS에서 제공하는 기능을 이용하거나, 별도의 암호화 프로그램을 사용하여 암호화함을 원칙으로 한다.

3 회사의 중요 데이터에 대해서는 위·변조 방지기능을 적용하여 데이터 무결성을 보장한다.

4 기타 DB의 암호화에 대한 방법 및 관리 절차는 암호화지침에 정한 바에 따른다.

제33조(테스트데이터 관리)

1 회사는 개발·테스트 시 임의의 테스트데이터를 생성하여 활용하거나 운영시스템의 데이터를 가공하여 사용하여야 하며, 실제 이용자 정보는 사용을 금지한다.

2 회사는 제1항에 따라 운영시스템의 데이터를 가공하여 사용하는 경우 사용목적 달성 또는 사용기간 경과 후 즉시 삭제하여야 한다.

제4절 정보보호시스템

제34조(정보보호시스템 접근통제)

- 1 회사의 정보보호시스템에 직접 접근할 수 있는 사용자는 인가받은 사용자로 제한하며, 최소한의 사내 IP에서만 접속 가능하도록 설정하여야 한다.
- 2 정보보호시스템 접속 시 암호화된 인증방식(SSH, SSL 등)을 사용하여 하며, 사용자는 추가인증을 거쳐 접속하여야 한다.
- 3 회사는 정보보호시스템의 접근에 대한 접속로그를 남기도록 설정하여야 하며, 주기적으로 접속로그를 검토하여야 한다.

제35조(정보보호시스템 운영)

- 1 회사는 외부망과 연계되는 중요 위치에 방화벽 및 침입방지 시스템(또는 침입탐지시스템)을 설치하여 운영하여야 하며, 운영 결과는 1년 이상 보관하여야 한다.
- 2 회사는 정보보호시스템은 최소한의 서비스번호(port)와 기능만을 적용하고 업무목적 이외의 기능 및 프로그램을 제거하여야 한다.
- 3 회사는 정보보호시스템의 상태 정보, 발생하는 경보 및 이벤트에 대해 모니터링 등을 통해 작동 상태를 주기적으로 점검하여야 하며 그 결과를 분석하여야 한다.
- 4 정보보호시스템의 장애, 가동중지 등 긴급사태에 대비하여 백업 및 복구 절차를 수립하고 시행하여야 한다.

제36조(정보보호시스템 룰 셋 관리)

- 1 회사는 외부로부터 회사 내부로의 접속은 서비스를 위하여 꼭 필요한 경우만을 허용하는 것을 원칙으로 하여야 한다.
- 2 시스템 운영자는 정보보호시스템의 보안정책을 등록·변경·삭제하는 경우 대상 IP, 서비스번호(Port), 적용 기간, 사유 등을 기록한 신청서를 작성하고, 시스템 운영관리자의 승인을 받은 후 정책을 변경하여야 하며 변경 이력을 1년 이상 보관하여야 한다.
- 3 시스템 운영자는 반기 1회 이상 정보보호시스템 보안정책을 점검하여 사용하지 않거나 사용 기간이 경과된 정책을 삭제하여야 한다. 삭제 시 제2항의 절차에 따른다.

제5절 클라우드컴퓨팅서비스

제37조(클라우드컴퓨팅서비스 이용절차 등)

- 1 회사는 클라우드컴퓨팅서비스를 이용하고자 하는 경우 다음 각 호의 절차를 수행하여야 한다.
 - 1) 자체적으로 수립한 기준에 따른 이용대상 정보처리시스템의 중요도 평가
 - 2) 클라우드컴퓨팅서비스 제공자의 건전성 및 안전성 등 평가
 - 3) 자체 업무 위수탁 운영기준의 마련 및 준수

- 2 제1항에 따른 평가결과 및 자체 업무 위수탁 운영기준에 대해 정보보호위원회의 심의·의결을 거쳐야 한다.
- 3 회사는 다음 각 호의 어느 하나에 해당하는 사유가 발생한 날로부터 3개월 이내에 금융감독원장에게 보고하여야 하고, 관련 서류를 최신상태로 유지하여야 한다
- 1) 클라우드컴퓨팅서비스 이용계약을 신규로 체결하거나, 기존 클라우드컴퓨팅서비스 이용계약을 통해 신규 업무를 처리하는 경우
 - 2) 클라우드컴퓨팅서비스 제공자의 합병, 분할, 계약상 지위의 양도, 재위탁 등 중대한 변경사항이 발생한 경우
 - 3) 클라우드컴퓨팅서비스 제공자가 서비스품질의 유지, 안전성 확보 등과 관련한 중요 계약사항을 이행하지 아니한 경우
 - 4) 클라우드컴퓨팅서비스 제공자의 건전성 및 안정성 등에 대한 평가에 중대한 변경사항이 발생한 경우
 - 5) 클라우드컴퓨팅서비스 이용과 관련한 업무 연속성 계획 및 안전성 확보조치에 중대한 변경사항이 발생한 경우
- 4 제3항에 따라 금융감독원장에게 보고할 경우 첨부해야 하는 서류는 다음 각 호와 같다.
- 1) 「금융회사의 정보처리 업무 위탁에 관한 규정」 제7조제1항 각 호에 관한 서류
 - 2) 제1항제1호에 따른 자체 중요도 평가 기준 및 결과
 - 3) 클라우드컴퓨팅서비스 제공자의 건전성 및 안전성 등에 대한 평가 결과
 - 4) 클라우드컴퓨팅서비스 이용 관련 업무연속성계획 및 안전성 확보조치에 관한 사항
 - 5) 제2항에 따른 정보보호위원회 심의·의결 결과
 - 6) 전자금융감독규정 <별표 2의5>의 계약서 주요 기재사항을 포함한 클라우드컴퓨팅 서비스 이용계약서
- 5 회사는 제4항 각 호에 따른 서류를 최신 상태로 유지하여야 하며, 금융감독원장의 요청이 있을 경우 이를 지체 없이 제공하여야 한다.
- 6 제2항의 절차를 거친 클라우드컴퓨팅서비스 제공자의 정보처리시스템이 위치한 전산실에 대해서는 전자금융감독규정 제11조 제11호 및 제12호, 제15조 제1항 제5호를 적용하지 아니한다. 다만, 회사가 제3항제1호에 따른 고유식별정보 또는 개인신용정보를 클라우드컴퓨팅 서비스를 통하여 처리하는 경우에는 전자금융감독규정 제11조 제12호를 적용하고, 해당 정보처리시스템을 국내에 설치하여야 한다.

제38조(클라우드컴퓨팅서비스 보안 관리)

회사의 클라우드컴퓨팅서비스 이용 관련 계정관리, 접근통제 등의 보안 관련한 사항은 이 지침 및 「클라우드 서비스 이용 매뉴얼」에서 정한 바를 준용한다.

부칙

제1조(시행일) 이 지침의 시행일은 대표이사가 승인한 날로 한다.